



רסומנט



|                                                                |          |
|----------------------------------------------------------------|----------|
| <b>1. Incident Overview</b>                                    | <b>3</b> |
| <b>2. Investigation and Key Findings</b>                       | <b>3</b> |
| 2.1 Malicious Activity Involving Security Products             | 3        |
| 2.2 Use of a Highly Customized Withdrawal Tool to Steal Assets | 3        |
| 2.3 Asset Transfers and Subsequent Withdrawal Attempts         | 4        |
| <b>Disclaimer</b>                                              | <b>5</b> |

## 1. Incident Overview

On September 25, 2026, the SlowMist security team was invited by Bitget to investigate the theft of assets from its hot wallets. As of September 29, we have identified malicious activity involving two third-party security products and a wallet application host. We have also recovered a customized withdrawal tool used by the attacker. We are continuing to investigate how the attacker moved between the systems involved.

The following summarizes the investigation's progress as of September 29. The two third-party security products are referred to as Product A and Product B. All times are in UTC+8.

## 2. Investigation and Key Findings

### 2.1 Malicious Activity Involving Security Products

The earliest malicious activity identified in the available logs dates to August 31. A service running on one of Product A's nodes was affected by a zero-day vulnerability. The attacker ran a hidden script under the service process, launched a command to read the environment variable containing the database password, and connected to the database. Similar hidden-script activity was observed on two other nodes on September 23 and September 25. These findings show that the affected service environments had already been compromised before the assets were transferred out.

In the early hours of September 25, the attacker accessed Product B's management platform using an internal employee's identity. Starting at 00:07, the attacker made three consecutive attempts to inject system commands into Product B's task parameters to write malicious files. The attacker subsequently submitted code through the platform's web execution endpoint, attempting to modify server configuration, write a communication relay file, and upload and assemble malicious program files in batches.

### 2.2 Use of a Highly Customized Withdrawal Tool to Steal Assets

A key finding was the recovery of a highly customized withdrawal tool from files the attacker had deleted. The tool was tailored to the wallet system's withdrawal logic. It forged risk-control

*\* The information enclosed is intended solely for the use of the designated recipient(s).*

*\* Any unauthorized use, disclosure, or distribution of this report is strictly prohibited.*

parameters in its code, constructed withdrawal requests, and invoked the withdrawal process. The host log shows that the relevant malicious program began running and executing cryptocurrency theft at 01:49 on September 25.

## 2.3 Asset Transfers and Subsequent Withdrawal Attempts

On-chain verification shows that the earliest transfer verified to date occurred at 02:31:00 on September 25, when the attacker's address received 93 TRX. Eleven seconds later, the receiving address on Ethereum received 0.84 ETH. The compiled transfer records extend to 05:23:11 that day, spanning approximately 2 hours and 52 minutes across multiple blockchains.

After the asset transfers had begun, the attacker also attempted to modify withdrawal records directly in the wallet database and invoke withdrawal tasks on the local host. Logs show that two fabricated BTC withdrawal orders entered processing and returned errors. They also record the attacker subsequently reviewing logs, querying order status, and making further attempts. These actions occurred after 05:22 and were part of the subsequent BTC withdrawal attempts.

*\* The information enclosed is intended solely for the use of the designated recipient(s).*

*\* Any unauthorized use, disclosure, or distribution of this report is strictly prohibited.*

## Disclaimer

SlowMist issues this report based on facts that occurred or existed before its publication and assumes responsibility only in relation to those facts. SlowMist cannot assess the project's security status in light of facts that occur or arise after publication and assumes no responsibility for them. The security analysis and other content in this report are based on documents and materials supplied to SlowMist by the information providers up to the date of this report (the "Provided Information"). SlowMist assumes that the Provided Information contains no omissions and has not been tampered with, deleted, or concealed. If the Provided Information is incomplete, has been tampered with, deleted, or concealed, or does not reflect the actual circumstances, SlowMist shall not be liable for any resulting losses or adverse consequences. SlowMist's work is limited to conducting the agreed security analysis of the project and issuing this report. SlowMist assumes no responsibility for the project's background or other circumstances.

*\* The information enclosed is intended solely for the use of the designated recipient(s).*

*\* Any unauthorized use, disclosure, or distribution of this report is strictly prohibited.*



## **Official Website**

[www.slowmist.com](http://www.slowmist.com)



## **E-mail**

[team@slowmist.com](mailto:team@slowmist.com)



## **Twitter**

[@SlowMist\\_Team](https://twitter.com/SlowMist_Team)



## **Github**

<https://github.com/slowmist>